

Dangling DNS on courtside.gleague.nba.com -> Firebase Hosting with no associated site (potential subdomain takeover)

Target: <https://courtside.gleague.nba.com/>

Program: NBA Public Bug Bounty (HackerOne - nba-public)

Severity (proposed): Medium - subdomain takeover candidate on a legitimate *.nba.com property.

Exploitation (the actual domain claim) was not performed; see *Caveats*.

Date: 2026-09-03

Reporter test account: N/A - issue is fully unauthenticated.

Summary

courtside.gleague.nba.com is an NBA G League subdomain whose DNS A records point to Firebase Hosting's published IP addresses, but no Firebase Hosting site is associated with the domain. Firebase therefore serves its default "Site Not Found" page for every request.

If the domain's association with Firebase Hosting is in a stale/orphaned state (e.g. it was previously connected to a now-deleted Firebase project), an attacker who adds courtside.gleague.nba.com as a custom domain to a Firebase project they control would be able to serve arbitrary content from a legitimate nba.com subdomain.

Steps to reproduce

1. Resolve the host:

```
$ dig +short courtside.gleague.nba.com
151.101.65.195
151.101.1.195
```

151.101.1.195 and 151.101.65.195 are the A records Firebase Hosting instructs customers to use for custom domains (see Firebase Hosting docs -> "Connect a custom domain").

2. Request the site:

```
$ curl -sI https://courtside.gleague.nba.com/
HTTP/2 404
content-type: text/html; charset=utf-8
x-served-by: cache-bsb500031-BSB          # Fastly = Firebase Hosting's CDN
x-cache: MISS

$ curl -s https://courtside.gleague.nba.com/ | grep -iE '<h1>|<h2>'
<h1>Site Not Found</h1>
<h2>Why am I seeing this?</h2>
<h2>How can I deploy my first app?</h2>
```

This is the verbatim Firebase Hosting "Site Not Found" page - it is returned when a request reaches Firebase Hosting for a hostname that is not attached to any active site.

3. (Not performed - see *Caveats*) An attacker would then:

- create a Firebase project,

- firebase hosting:sites:create <attacker-site>,
- in the Firebase console -> Hosting -> "Add custom domain", enter courtside.gleague.nba.com.
- If Firebase associates the domain without requiring a fresh TXT ownership record on nba.com (which can happen when a prior verification/connection was not cleaned up), the attacker now controls all content at <https://courtside.gleague.nba.com/>.

Proof of concept (evidence)

Request:

```
GET / HTTP/2
Host: courtside.gleague.nba.com
```

Response:

```
HTTP/2 404 Not Found
content-type: text/html; charset=utf-8
<!doctype html><html><head><title>Site Not Found</title> ...
<h1>Site Not Found</h1>
<h2>Why am I seeing this?</h2>
... "How can I deploy my first app?" ...
```

- DNS: courtside.gleague.nba.com -> A 151.101.1.195, 151.101.65.195 (Firebase Hosting).
- HTTP: 404 + Firebase Hosting "Site Not Found" default page.
- No NBA / G League content is served; the hostname is orphaned at the hosting layer.

Impact

Demonstrated: A valid NBA G League subdomain (courtside.gleague.nba.com) resolves to Firebase Hosting but is not attached to any site - a dangling-DNS condition.

Worst case (if the domain is claimable): full control of content served from <https://courtside.gleague.nba.com/>, enabling:

- Phishing / brand abuse under a trusted nba.com domain with a valid TLS certificate (Firebase auto-provisions one).
- Cookie attacks against other *.nba.com properties. NBA sets cookies with Domain=.nba.com - observed on *.gleague.nba.com responses, e.g. Akamai Bot Manager cookies _abck and bm_sz (Set-Cookie: _abck=...; Domain=.nba.com). Content the attacker serves from courtside.gleague.nba.com can set/overwrite Domain=.nba.com cookies, enabling session fixation or bot-management bypass against users of unrelated NBA sites.
- Malware / scam distribution with the credibility of an official NBA domain.
- OAuth redirect_uri abuse if any NBA SSO client (PingFederate / Azure AD are both in use across *.nba.com) allows a *.nba.com or *.gleague.nba.com redirect target.

Remediation

- If courtside.gleague.nba.com is no longer used: remove its DNS records.
- If it is used: re-attach it to the correct Firebase Hosting site under NBA's Firebase project.
- Audit related records for the same class of issue - during testing, *.dleague.nba.com (austin, bakersfield, canton, grandrapids, greensboro) were found with CNAME -> vpc-lb-1679823851.us-east-1.elb.amazonaws.com, which resolves (3.212.84.195) but does not respond on

- 80/443. Confirm that ELB still exists and is intended.
- Consider a periodic dangling-DNS sweep across *.nba.com.

Caveats (read before triage)

-
- The takeover itself was not attempted. This report documents (1) the dangling-DNS condition and (2) the Firebase Hosting "Site Not Found" fingerprint, which is the standard precondition for a Firebase subdomain takeover. Whether the domain is actually claimable depends on internal state you can verify directly: is there a Firebase project that still "owns"/half-owns this custom domain, and does re-adding it bypass fresh TXT verification? Modern Firebase requires a TXT ownership record for new custom-domain connections; this is exploitable primarily when a prior connection/verification was left in place.
 - Scope confirmation needed. courtside.gleague.nba.com matches the in-scope pattern *.gleague.nba.com (the program's scoped sample includes wisconsin/windycity/westchester.gleague.nba.com). Please confirm it is covered by nba-public before rewarding.
 - Cookie values in the evidence above are illustrative and should be treated as sensitive.

Submission checklist

-
- [x] Scope: matches *.gleague.nba.com pattern - confirm courtside in nba-public CSV
 - [x] Reproducible without reporter session state (fully unauthenticated)
 - [x] No reporter test account required
 - [x] No third-party PII; cookie values flagged as sensitive
 - [x] Request + response of the key step included
 - [x] Minimal PoC - no takeover performed
 - [x] Severity calibrated (Medium; exploitation not performed)
 - [] Duplicate check - verify against NBA known issues / recent gleague.nba.com DNS disclosures

Human reviews and submits. Claude does not submit.